

주 의 사 항

1. 제 목 : 정보시스템 보안관리 부적정
2. 관계기관 : ★★보훈병원
3. 내 용 : ★★보훈병원에서는 보훈병원EMR, 통합경영정보시스템, 그룹웨어 등 내부 업무시스템 및 문서작업, 업무관련 자료검색 등을 위해 PC를 이용하고 있습니다.

가. 서버 및 네트워크 보안관리 부적정

공단 「정보보안업무 처리지침」 제22조(서버 보안관리)제1항에 따르면 서버 관리자는 서버를 도입 운용할 경우, 해킹을 통한 자료 절취, 위·변조 등에 대비하여 서버의 운용에 필요한 서비스 포트 외에 불필요한 서비스 포트 제거 및 관리용서비스와 사용자용 서비스를 분리 운용 등 보안대책을 수립·시행하여야 한다고 명시되어 있습니다.

또한, 동 지침 제30조(네트워크장비 보안관리)제1항제4호에 따르면 시스템 관리자는 네트워크 장비 운용과 관련하여 FTP¹⁾ 등 불필요한 서비스 포트 및 사용자 계정 차단·삭제 등의 보안조치를 강구해야 한다고 명시하고 있습니다.

따라서, ★★보훈병원에서는 업무시스템 이용을 위한 필수 서비스 포트 외에 서버 및 사용자PC에 개방되어 있는 불필요한 서비스 포트를 차단하여 해당 포트를 통해 내부 시스템 및 업무용 PC에 접근할 수 있는 경로를 사전에 제거하는 등의 보안조치를 취하여야 합니다.

그런데, ★★보훈병원 감사기간 중 개방되어 있는 서비스 포트를 확인한 결과 [그림 1]과 같이 보안에 취약한 서비스 포트를 제거하지 않고 사용하고 있는 사실이 있습니다.

1) FTP(File Transfer Protocol) : 인터넷을 통해 한 컴퓨터에서 다른 컴퓨터로 파일을 전송할 수 있도록 하는 방법과, 그런 프로그램을 모두 일컫는 말.

[그림 1] 네트워크 서비스 포트 검출현황

IP Address	MAC Address	Response Time	Host Name	TCP Ports
2		0 ms		23, 80
2		0 ms		23, 80
2		0 ms		
2		13 ms		
2		0 ms		21, 23, 25, 80, 110
2		0 ms		80
2		1 ms		
2		0 ms		
2		0 ms		
2		0 ms		
2	6-1B~...	0 ms	은행 100026	
2		0 ms		21, 23, 110
2		0 ms		21, 23, 110
2		0 ms		21, 23, 110
2		0 ms		80
2		0 ms	sn2 (SVRI4TA	21, 23, 110
2		0 ms	sn1	21, 23, 110
2		0 ms	sn1 100068	21
2		0 ms	부 100071	21
2		0 ms	sn1 100076	21, 23, 110
2		0 ms	부 100076	21
2		0 ms		
2		0 ms	실 100080	
2		0 ms	실 100083	80
2		0 ms	부 100085	21
2		0 ms		
2		0 ms	부 100086	21
2		0 ms	부 100088	21
2		0 ms	부 100089	21
2		0 ms		
2		0 ms	부 100091	21
2		0 ms	부 100096	21

나. PC 등 단말기 보안관리 부적정

공단 정보보안업무 처리지침 제15조(PC등 단말기 보안관리)제2항제4호에 따르면 비인가자가 PC 등을 무단으로 조작하여 전산자료를 절취, 위·변조 및 훼손 시키지 못하도록 업무상 불필요한 응용프로그램 설치 금지 및 공유폴더 삭제 등의 보안조치를 하여야 한다고 명시하고 있습니다.

최근 정보보안과 관련하여 해킹사고 사례를 보면 정보시스템의 보안취약점을 악용하여 고객의 정보를 빼내어 금전 요구, 전산망 마비 등으로 고객의 신뢰를 무너뜨리고 있어 정보보호에 대한 각별한 관리가 필요합니다.

[표 1] 최근 국내 해킹 사고 사례

시 기	기 관	유 형	피해규모
2018년 6월	우리은행	개인정보유출	5만 명
2017년 7월	비트코인 거래소 빗썸	개인정보유출	3만 명
2016년 7월	인터파크	개인정보유출	1,030만 건
2014년 3월	국토교통부	개인정보유출	2,000만 명
	SKT, LG U+	개인정보유출	1,230만 명
	KT	개인정보유출	1,200만 명
2013년 3월	MBC, KBS, 신한은행, 농협 등	전산망 마비	서버, PC, ATM 등 4만 8,000여대 시스템 마비

따라서, ★★보훈병원에서는 각 부서에서 보안에 취약한 공유폴더를 사용하지 않도록 하여 해당업무 담당자 이외 비인가자에게 환자 개인정보 등의 자료가 노출되지 않도록 관리하여야 합니다.

그런데, ★★보훈병원 감사기간 중 병원 내 네트워크에서 공유폴더 이용 실태를 확인한 결과 [그림 2]와 같이 원무1부, 영상의학과 등에서 내·외부 접근이 용이한 공유폴더를 이용중인 사실이 있습니다.

[그림 2] 공유폴더 이용 현황

이름	수정된 날짜	유형	크기
1월	2018-04-18 오후 ...	파일 폴더	
2월	2018-06-22 오후 ...	파일 폴더	
3월	2018-08-03 오후 ...	파일 폴더	
4월	2018-08-06 오후 ...	파일 폴더	
5월	2018-09-04 오전 ...	파일 폴더	
6월	2018-08-01 오후 ...	파일 폴더	
7월	2018-08-20 오후 ...	파일 폴더	
8월	2018-09-07 오전 ...	파일 폴더	
9월	2018-09-06 오전 ...	파일 폴더	
10월	2018-04-04 오후 ...	파일 폴더	
11월	2018-04-04 오후 ...	파일 폴더	
12월	2018-04-04 오후 ...	파일 폴더	
2018년 - 바로 가기	2018-02-01 오후 ...	바로 가기	1KB

이름	수정된 날짜	유형	크기
1. 접수업무	2017-07-20 오후 ...	파일 폴더	
2. 내·외부 업무	2017-09-11 오후 ...	파일 폴더	
3. 건수 통계	2017-07-20 오후 ...	파일 폴더	
4. 통계	2017-07-20 오후 ...	파일 폴더	
5. 청구	2017-07-20 오후 ...	파일 폴더	
6. 건수 통계	2017-07-20 오후 ...	파일 폴더	
7. 요청 사항	2017-07-20 오후 ...	파일 폴더	
준비 전후	2014-08-05 오전 ...	Microsoft Excel ...	19KB
근평	2017-02-16 오후 ...	한컴오피스 한글 ...	34KB
국무기술서	2016-12-12 오전 ...	한컴오피스 한글 ...	46KB
화)	2018-09-04 오후 ...	텍스트 문서	1KB
금)	2018-02-28 오후 ...	텍스트 문서	1KB
과 접수 업무 현황	2017-07-12 오전 ...	Microsoft Excel ...	17KB
환자정리	2017-02-01 오전 ...	한컴오피스 한글 ...	35KB
금)	2018-09-07 오전 ...	텍스트 문서	1KB

4. 조치할 사항

○ ★★보훈병원장은

- “가”사항 관련, 해킹을 통한 병원 내 환자정보, 직원정보 등 자료 절취, 위·변조 등에 대비하여 서버의 운용에 필요한 서비스 포트 외에 불필요한 서비스 포트를 제거 하는 등 보안조치를 취하시고,(권고)
- “나”사항 관련, 비인가자가 PC 등을 무단으로 조작하여 전산자료를 절취, 위·변조 및 훼손시키지 못하도록 병원 내 PC 등에서 이용중인 공유폴더의 삭제 등 보안조치를 취하시기 바랍니다.(통보)
- 또한, 앞으로 동일사례가 재발되지 않도록 관련자에게 「주의」 조치하시기 바랍니다. (주의)